

Marco Integrativo GQM + PRAGMATIC para Indicadores CMMC / NIS2 / ENS

Versión: 1.0

Propósito: Alinear objetivos nacionales y corporativos con indicadores técnicos de ciberseguridad inspirados en CMMC, evaluando además la calidad de cada métrica bajo los criterios PRAGMATIC.

1. Recordatorio breve: GQM y PRAGMATIC

1.1. GQM (Goal-Question-Metric)

El enfoque **Goal-Question-Metric (GQM)** propone definir primero los objetivos, después las preguntas que permiten evaluar el grado de cumplimiento de esos objetivos y, por último, las métricas que responden a dichas preguntas.[web:53][web:56][web:60][web:66]

- Goal (Objetivo): Qué queremos lograr y sobre qué objeto (organización, proceso, sistema...).
- Question (Pregunta): Qué debemos preguntar para saber si avanzamos hacia el objetivo.
- Metric (Métrica): Qué datos concretos medimos para responder a la pregunta con evidencia.

1.2. PRAGMATIC

El marco **PRAGMATIC** define nueve criterios para evaluar la utilidad de una métrica:[web:58][web:61][web:64][web:67]

- P – Predictivo: Ayuda a anticipar resultados futuros.
- R – Relevante: Conectada con objetivos y riesgos reales.
- A – Accionable: Permite tomar decisiones concretas.
- G – Genuino: Mide lo que dice medir, sin artificios.
- M – Significativo (Meaningful): Fácil de entender y explicar.
- A – Preciso (Accurate): Fiable en términos de exactitud.
- T – Oportuno (Timely): Disponible con la frecuencia necesaria.
- I – Independiente: No manipulado por quienes son evaluados.
- C – Rentable (Cheap): Su coste de obtención es razonable.

Cada criterio puede puntuarse, por ejemplo, de 0 a 5, generando un “metamétrica” de calidad de la métrica.

2. Ejes GQM aplicados a indicadores CMMC

Tomamos algunos indicadores clave del informe previo CMMC/NIST (adaptables a ámbito nacional español) y los estructuramos en GQM.

2.1. Ejemplo 1 – Cobertura de MFA en cuentas críticas

Goal G1

Asegurar que los accesos a sistemas críticos están fuertemente autenticados, reduciendo la probabilidad de compromiso de credenciales y accesos no autorizados (alineado con NIST 800-171 IA-2, IA-5, CMMC AC/IA y ENS).[web:18][web:20][web:26][web:65]

Questions asociadas

- Q1.1: ¿Qué porcentaje de cuentas con acceso a sistemas críticos utiliza MFA robusta?
- Q1.2: ¿Qué porcentaje de accesos remotos a sistemas críticos se protege con MFA?
- Q1.3: ¿Se aplican excepciones y cómo se gestionan?

Metrics

- M1.1: $\%_{\text{Cuentas_criticas_MFA}} = (\text{N}^\circ \text{ de cuentas críticas con MFA} / \text{N}^\circ \text{ total de cuentas críticas}) \times 100$.
- M1.2: $\%_{\text{Accesos_remotos_MFA}} = (\text{N}^\circ \text{ accesos remotos a sistemas críticos con MFA} / \text{N}^\circ \text{ total accesos remotos a sistemas críticos}) \times 100$.
- M1.3: $\text{N}^\circ_{\text{excepciones_MFA}} \text{ y } \%_{\text{excepciones_MFA}} \text{ sobre el total de cuentas críticas}$.

2.2. Ejemplo 2 – Tiempo medio de parcheo de vulnerabilidades críticas

Goal G2

Reducir la ventana de exposición a vulnerabilidades críticas en sistemas expuestos, alineado con buenas prácticas NIST, CMMC y ENS/NIS2.[web:18][web:20][web:62][web:65]

Questions

- Q2.1: ¿Cuál es el plazo medio de aplicación de parches críticos en sistemas expuestos a internet?
- Q2.2: ¿Qué porcentaje de sistemas críticos tiene todas las vulnerabilidades críticas corregidas dentro del plazo objetivo?
- Q2.3: ¿Cuál es el número medio de vulnerabilidades críticas abiertas por activo crítico?

Metrics

- M2.1: $\text{MTTP_critico} = \text{tiempo medio (en días) desde publicación/identificación de parche crítico hasta su implantación en sistemas expuestos}$.
- M2.2: $\%_{\text{Sistemas_cumplen_SLA_parcheo_critico}}$.
- M2.3: $\text{Media_vuln_criticas_por_activo}$.

2.3. Ejemplo 3 – Monitorización y respuesta (MTTD / MTTR)

Goal G3

Mejorar la capacidad de detección y respuesta a incidentes significativos, minimizando impacto y duración de las interrupciones (NIST 800-171 IR/AU, CMMC IR, ENS y NIS2).[web:18][web:21][web:62][web:63][web:65]

Questions

- Q3.1: ¿Cuál es el tiempo medio de detección de incidentes significativos (MTTD)?
- Q3.2: ¿Cuál es el tiempo medio de contención y recuperación (MTTR)?
- Q3.3: ¿Qué porcentaje de incidentes significativos tiene análisis de causa raíz y plan de acción?

Metrics

- M3.1: $\text{MTTD_incidentes_significativos (horas/días)}$.
- M3.2: $\text{MTTR_incidentes_significativos (horas/días)}$.

- M3.3: %_Incidentes_con_postmortem = (Nº incidentes con análisis y plan / Nº total incidentes significativos) × 100.

2.4. Ejemplo 4 – Clasificación y cifrado de información sensible (CUI-like / datos críticos)

Goal G4

Garantizar que la información sensible está identificada, clasificada y protegida mediante cifrado y controles de acceso adecuados.[web:18][web:20][web:21][web:65]

Questions

- Q4.1: ¿Qué porcentaje de activos de datos sensibles está formalmente clasificado?
- Q4.2: ¿Qué porcentaje de datos sensibles se cifra en reposo según políticas aprobadas?
- Q4.3: ¿Qué porcentaje de canales que transportan datos sensibles utilizan cifrado robusto?

Metrics

- M4.1: %_Activos_datos_clasificados.
- M4.2: %_Datos_sensibles_cifrados_en_reposo.
- M4.3: %_Canales_sensibles_cifrados_en_transito.

2.5. Ejemplo 5 – Gestión de proveedores críticos

Goal G5

Asegurar que los proveedores críticos alcanzan niveles mínimos de seguridad compatibles con el riesgo asumido y los marcos regulatorios (NIS2, ENS, DORA).[web:21][web:63]

Questions

- Q5.1: ¿Qué porcentaje de proveedores críticos están identificados y categorizados?
- Q5.2: ¿Qué porcentaje de contratos con proveedores críticos incluye requisitos de seguridad verificables?
- Q5.3: ¿Qué porcentaje de proveedores críticos se evalúa periódicamente con métricas estructuradas?

Metrics

- M5.1: %_Proveedores_criticos_identificados.
- M5.2: %_Contratos_criticos_con_clausulas_seguridad_robustas.
- M5.3: %_Proveedores_criticos_evaluados_anualmente.

2.6. Ejemplo 6 – Cultura, formación y simulaciones

Goal G6

Desarrollar una cultura de ciberseguridad sólida mediante formación adaptada por rol y ejercicios prácticos.[web:18][web:21][web:63][web:65]

Questions

- Q6.1: ¿Qué porcentaje de la plantilla recibe formación anual en ciberseguridad?
- Q6.2: ¿Con qué frecuencia se realizan simulaciones de phishing y cuál es la tasa de clics?
- Q6.3: ¿Qué nivel de reporte voluntario de incidentes o sospechas existe?

Metrics

- M6.1: %_Plantilla_formacion_anual.
- M6.2: Frecuencia_simulaciones_phishing y Tasa_clicks_phishing.
- M6.3: N°_reportes_voluntarios_por_100_empleados.

2.7. Ejemplo 7 - Documentación y evidencias (SSP, POA&M)

Goal G7

Disponer de documentación estructurada (SSP, POA&M, evidencias) que permita demostrar y mejorar el cumplimiento de medidas de seguridad.[web:18][web:31][web:32][web:42]

Questions

- Q7.1: ¿Existe y se mantiene un System Security Plan (SSP) para los sistemas relevantes?
- Q7.2: ¿Qué porcentaje de controles clave tiene evidencias actualizadas?
- Q7.3: ¿Qué porcentaje de acciones POA&M están completadas dentro del plazo?

Metrics

- M7.1: Estado_SSP (escala 0-4: inexistente → vivo y actualizado).
- M7.2: %_Controles_con_evidencias_actualizadas.
- M7.3: %_Acciones_POAM_completadas_en_plazo.

3. Evaluación PRAGMATIC de las métricas

Para cada métrica definida, se recomienda puntuación 0-5 en cada criterio PRAGMATIC.[web:58]
[web:61][web:64][web:67]

Ejemplo de plantilla conceptual:

Métrica	P (Predictivo)	R (Relevante)	A (Accionable)	G (Genuino)	M (Signif.)	A (Preciso)	T (Oportuno)	I (Independ.)	C (Rentable)	Total (0-45)
%_Cuentas_criticas_MFA	4	5	5	5	5	4	4	3	4	39
MTTP_critico	4	5	5	4	4	4	3	3	3	35
MTTD_incidentes	5	5	5	4	4	3	3	3	3	35

Se puede fijar un umbral (por ejemplo, $\geq 30/45$) para considerar una métrica “apta para gobernanza”.

4. Encaje con indicadores nacionales (España)

Los objetivos “G” pueden alinearse explícitamente con:

- Objetivos nacionales de resiliencia (planes de ciberseguridad, NIS2).[web:21][web:63]
- Metodologías nacionales de evaluación de ciberresiliencia (por ejemplo, metodologías de INCIBE/IMC).[web:63]
- Informes nacionales de incidentes para calibrar niveles de madurez y metas realistas.[web:37][web:40][web:43]

Así, por ejemplo:

- G3 (MTTD/MTTR) se alinea con objetivos nacionales de reducir el impacto de incidentes reportados.
- G5 (proveedores) se alinea con la necesidad regulatoria de gestionar riesgos en la cadena de suministro bajo NIS2 y DORA.

5. Resumen operativo

1. Definir objetivos (G) alineados con estrategia nacional/sectorial y CMMC/NIST.
2. Derivar preguntas (Q) que operativicen esos objetivos en lenguaje de responsable de seguridad.
3. Derivar métricas (M) que sean medibles con datos disponibles o razonablemente obtenibles.
4. Evaluar cada métrica con PRAGMATIC y quedarse con las que superen un umbral de calidad.
5. Integrar las métricas “seleccionadas” en cuadros de mando, plantillas Excel y reportes ejecutivos.

Fin del Marco Integrativo GQM + PRAGMATIC.